

ServiceNow Security Best Practices Guide

Key considerations for securing
ServiceNow instances

Release: Zurich

Introduction



[Video: Security Best Practices for the ServiceNow AI Platform](#)

Document goal and structure

This document provides a comprehensive overview of key considerations for securing a ServiceNow instance under the Shared Responsibility model where both the service provider and the customer share accountability for security and compliance.

Each section is structured around the categories of Governance, Identify, Protect, Detect, Respond, and Recover, which reflect the natural progression of effective management and response. Within those sections, best practices follow a “crawl, walk, run” order.

The focus of this guide is recommendations, rather than detailed platform descriptions. All stakeholders should review the white paper for full details.

This document is designed to be read alongside [Securing the ServiceNow AI Platform](#) which gives a holistic overview of the physical, administrative, and technical controls ServiceNow has in place to protect customer data.

In this document, security and compliance is considered from the perspective of the [National Institute of Standards and Technology \(NIST\) Cybersecurity Framework \(CSF\)](#). The CSF is a set of voluntary guidelines, standards, and practices made available by NIST, an agency of the United States Department of Commerce.

This Best Practices Guide is also available in the following languages: [Spanish](#), [French](#), [German](#), [Dutch](#), [Italian](#), [Brazilian Portuguese](#), [Korean](#), and [Japanese](#).

*Note: All information in this white paper is related to the **standard ServiceNow Commercial Cloud**.*

For information related to other globally located ServiceNow in-country cloud offerings and how these offerings may differ, please contact your ServiceNow account representative.



Table of Contents

Introduction 2

 Document goal and structure 2

Key concepts and reference material 5

 Intended audience 5

 Identify stakeholders 5

 Security_Admin role 5

 Best practice prioritization 5

 THE SHARED RESPONSIBILITY MODEL 6

GOVERN 7

Security contacts. 7

Data management and privacy compliance 8

 Data controller and data processor 8

Compliance: Regulatory and legal 10

 Data Security Addendum (DSA)
 and Data Processing Addendum (DPA) 10

Physical security and environmental controls 11

Cloud infrastructure security management. 12

Assess ServiceNow as a vendor 13

IDENTIFY 14

Instance management 14

PROTECT 15

Vulnerability management 15

Identity and access management 17

 Authentication 17

 Authorization 20

ServiceNow Security Center. 23

 Secure instance configuration 23



Encryption 25

 Data in transit 25

 Data at rest 26

AI security 28

Secure coding 31

MID Server security 32

Email security 34

File transfers and web services 36

Mobile application security 37

DETECT **38**

Logging and monitoring. 38

Penetration testing. 40

RESPOND **41**

Incident management. 41

RECOVER **43**

Business continuity and disaster recovery 43

 Backup restoration 44

 Media disposal and destruction 44

Conclusion 45

Resources 45

Key concepts and reference material

Intended audience

This guide is specifically designed for instance administrators to collaborate closely with security and compliance professionals. Engaging both parties is essential to effectively address the evolving landscape of digital threats, demonstrate due diligence, and sustain a robust security posture across the ServiceNow environment.

Identify stakeholders

At the outset of a best practice review, instance administrators are advised to identify the primary security and compliance stakeholders within their organization. Their expertise and insights will help tailor the best practices to the organization's specific risk profile and compliance requirements.

Engaging these partners early in the process not only streamlines decision making but also strengthens the organization's overall security posture throughout the ServiceNow environment.

Security_Admin role

[High Security Settings](#) and the [High Security plugin](#) are activated by default on new ServiceNow instances and they can provide an elevated privilege role called [security_admin role](#). This role allows users to create and change access controls and change High Security Settings. In the base system, only the default System Administrator (admin) user has the security_admin role. The customer admin should work with stakeholders, such as the company's security team, to determine if an elevated role assignment is required. The security_admin role should be assigned to a limited number of users and groups.

Best practice prioritization

Customers should to evaluate each best practice in collaboration with relevant stakeholders to determine applicability and evaluate potential risks. Therefore, they must work closely with security and compliance teams when identifying the best practices to address.

Customers should also work with all stakeholders to set the prioritization of each best practice.

ServiceNow stands ready to provide guidance and support once you've begun implementing these measures. Work with your account teams or open a [ServiceNow Support](#) case for more clarification.



Companies are expected to evaluate each best practice in collaboration with relevant stakeholders to determine applicability and evaluate potential risks.

The Shared Responsibility Model*

Security is a partnership between ServiceNow and the customer, both with specific responsibilities. Therefore, it is essential that each party understands their role in this partnership. Using the extensive capabilities of the ServiceNow AI Platform, customers can configure instances to meet their unique security policies and obligations while also complying with any regional or industry-specific requirements.

- As the **data controller**, the customer determines access rights to their instance and the data it contains. Security controls within the instance enable customers to implement policies appropriate to their own requirements and make decisions on data classification.
- As the **data processor**, ServiceNow secures the platform infrastructure and provides tools for security management and monitoring according to customer requirements.
- The **colocation facility** and the third-party **cloud service provider** (CSP) also have shared responsibilities with the data controller (customer) and data processor (ServiceNow).



For more information about security responsibilities concerning customer data, see the [ServiceNow Shared Responsibility Model overview](#).

This document includes shared responsibilities specified at the beginning of each section. Customers should review each customer responsibility with relevant stakeholders to ensure the organization fully understands its obligations as specified in the ServiceNow Shared Responsibility Model. Relevant stakeholders may include architecture teams, security teams, and compliance personnel.

Area of Responsibility	Responsibility		
	Customer	ServiceNow	Colocation Facility
Security contact details	●		
Data management and privacy compliance	●	●	
Compliance: Regulatory and legal	●	●	●
Physical security and environment controls		●	●
Cloud infrastructure security management		●	
Instance management	●		
Vulnerability management	●	●	
Identity and access management	●		
ServiceNow Security Center (SSC) secure instance configuration	●		
Data encryption in transit	●	●	
Data encryption at rest	●		
Encryption key management	●	●	
AI security	●	●	
Secure coding	●	●	
MID Server security	●		
Email security*	●	●	
File transfers and web services	●		
Mobile application security	●		
Logging and monitoring	●	●	
Penetration testing	●	●	
Incident management	●	●	
Business continuity and disaster recovery	●	●	●
Backup and restoration		●	
Media disposal and destruction		●	

* Customers are responsible for configuring aspects of security when they integrate the ServiceNow email capability.

GOVERN

Security contacts

Customer responsibility

As outlined in the DSA, customers are responsible for identifying and maintaining appropriate security contacts by identifying them in [ServiceNow Support Security Contacts](#).

Best practices

Create a process to update security contacts regularly

Ensure the security contact record within ServiceNow Support is always kept up to date, with details of at least two appropriate information security personnel. Set a reminder to review the security contact details at least quarterly to ensure they are current and accurate.

- Security contacts should be authorized to act on the information they receive, because it may be critically important to the organization.
- Use a distribution list in the security contact field when possible.

Additional information

- Update your [ServiceNow Support Security Contacts](#) (requires a ServiceNow Support account)

Data management and privacy compliance

Data controller and data processor

Customer responsibility

As the data controller, the customer is responsible for determining how data is collected, stored, used, shared, archived, destroyed, and for maintaining the accuracy and confidentiality of that data. The customer is also responsible for meeting their requirements as a data controller under the applicable data protection laws.

Additionally, customers are responsible for risks associated with their AI investments. ServiceNow has a premium offering, called [AI Control Tower](#), that can give customers visibility into their AI footprint by managing their AI asset inventory, configuration, state of AI cases, and approval flows.

For more detail on AI best practices refer to [AI security in the PROTECT section](#).

ServiceNow responsibility

As the data processor, ServiceNow supports the data controllers by providing features to enable access and control of data processing activities and obligations.

ServiceNow has a dedicated Cloud Assurance team responsible for several governance and compliance efforts across the organization, including managing the ServiceNow compliance program. ServiceNow is reviewed on an annual basis by independent third-party auditors. ServiceNow will establish and maintain sufficient controls to meet certification and attestation for the objectives stated in ISO/IEC [27001](#), [27017](#), [27018](#), [27701](#), [9001](#), [22301](#), [42001](#) (new AI/IT), and [SSAE 18 SOC 2 Type 2](#) (or equivalent standards) for the security program.

Best practices

Clarify stakeholder data responsibilities

Set up a process to regularly involve stakeholders in defining data responsibilities, making sure that controls meet internal policies and goals and are working as intended.

Classify data in the instance

Data classification is available to all customers and enables the identification and classification of stored data for each instance, ensuring that data controls meet organizational requirements, as agreed by the stakeholders.

Data classification is for data that is known. Data discovery allows the discovery of data in comment fields, description fields, or attachments. Data anonymization can be used to mitigate issues and limit risk.

Allocate roles within the instance according to data access requirements.

Identify which individuals are authorized to access data according to its classification, document these permissions, and establish roles that align with expected access requirements.

Best practices continued**Establish the data retention period and develop appropriate procedures**

Collaborate with stakeholders to assess your organization's data retention requirements and determine whether existing controls align with these standards.

Customers can define the criteria for archiving records by creating an archive rule, and can use a destroy rule to delete archived records after a specified amount of time.

Additional information

- [Data Classification](#)
- [Data Classification standard](#)
(Requires access to the ServiceNow CORE Compliance Portal. Find out how to access CORE [here](#).)
- [Create an archive rule](#)
- [Mark records for deletion \(destroy rule\)](#)
- [AI Control Tower documentation](#)

Compliance: Regulatory and legal

Data Security Addendum (DSA) and Data Processing Addendum (DPA)

Customer responsibility

Customers need to be aware that the terms and conditions governing the use of the ServiceNow AI Platform are dependent on their order form agreement with ServiceNow, including matters of data security and privacy.

The [Data Security Addendum \(DSA\)](#) covers key aspects of the ServiceNow security program: certifications and attestations, logging and monitoring, change control, and access administration, as well as other compliance and governance details.

The [Data Processing Addendum \(DPA\)](#) reflects the customer's agreement regarding personal data. The DPA also defines the roles of the **data controller** and **data processor**, and describes the nature, scope, and purpose of the processing.

ServiceNow provides the current versions of these addenda on [Legal: Customer Agreements and Terms](#) for general understanding; however, to understand the specific details, administrators are advised to reach out to their own compliance or legal support team.

Best practices

Review and understand the DSA and DPA terms and conditions

Consult with your compliance and legal teams to ensure they have read and understand the ServiceNow DSA and/or DPA.

Where applicable, review the [ServiceNow third party hosted product addendum](#)

Work with compliance and legal teams to address any questions regarding the use of ServiceNow subscription products that use data hosting provided by third-party sub-processors (third party hosted products).

Additional information

- [Legal: Customer agreements and terms](#)
- [Data Security Addendum \(DSA\)](#)
- [Data Processing Addendum \(DPA\)](#)
- [ServiceNow third party hosted product addendum](#)
- [Privacy/GDPR section in ServiceNow CORE](#)

Requires access to the ServiceNow CORE Compliance Portal. Find out how to access CORE [here](#).

Physical security and environmental controls

ServiceNow responsibility

ServiceNow performs colocation facility vendor reviews annually and periodically performs onsite assessments of physical and environmental controls.

ServiceNow colocation facility operations, security, and procurement personnel review the colocation facility provider SOC 2 Type 2 reports or other available assessments (e.g., ISO 27001) on an annual basis.

Additionally, through periodic visits to the facility, ServiceNow colocation facility operations and compliance personnel review the controls applicable to the services provided to ServiceNow.

- Routine meetings are held with vendor account management personnel to help ensure services are provided according to expectations.
- Cloud operations personnel review access activity within the colocation facility suites on a periodic basis to ensure access is appropriate.

Best practices

Review and understand physical security and environmental controls at ServiceNow

Establish a process involving relevant stakeholders to review the physical security and environmental controls information.

Additional information

- [Securing the ServiceNow AI Platform white paper](#)

The links below require access to the ServiceNow CORE Compliance Portal. Find out how to access CORE [here](#).

- [Colocation facility \(data center\) certifications](#)
- [Colocation facility \(data center\) access control management SOP](#)

Cloud infrastructure security management

ServiceNow responsibility

ServiceNow is responsible for maintaining a secure architecture within customer cloud environments. This includes implementing hardened configurations and supporting processes to protect sensitive data and ensure system integrity. Security measures in place include firewalls, secure logical access controls, and intrusion detection systems. ServiceNow also continuously monitors systems for vulnerabilities and malicious activity.

As the SaaS Cloud Solution Provider, ServiceNow manages the cloud infrastructure to ensure availability, scalability, security, and performance. Responsibilities include:

- Developing and enforcing security policies and controls
- Monitoring for potential threats
- Implementing access controls
- Ensuring compliance with applicable regulations and industry standards

Additional responsibilities include conducting security assessments, performing penetration testing, and responding promptly to potential security incidents.

Best practices

Review and understand cloud infrastructure security management at ServiceNow

Establish a structured process to regularly review the ServiceNow cloud infrastructure security management documentation. Ensure all relevant stakeholders are engaged in these reviews to maintain alignment, compliance, and awareness of security practices.

Additional information

- [Securing the ServiceNow AI Platform white paper](#)

The links below require access to the ServiceNow CORE Compliance Portal. Find out how to access CORE [here](#).

- [Change management SOP](#)
- [Patching Program SOP](#)
- [Backup and restoration SOP](#)
- [System configuration management SOP](#)
- [ServiceNow controlled access \(SNCA\) policy](#)
- [Corporate business continuity management policy](#)
- [Information system contingency plan \(ISCP\) and test report](#)
- [Information security policy](#)
- [Network overview and flow diagrams](#)
- [Security incident response SOP](#)
- [Global training policy](#)

Assess ServiceNow as a vendor

Customer responsibility

Third Party Risk Management represents a critical requirement for customers. Customers are expected to use the ServiceNow CORE Compliance Portal to access all relevant documentation required for internal and regulatory assessments. This includes reviewing certifications, attestations, and completed questionnaires, as well as standard operating procedures, policies, and other materials, in order to gain a comprehensive understanding of the ServiceNow security posture.

Access to the [ServiceNow CORE Compliance Portal](#) is managed by the customer, who controls user access, admin rights, and deprovisioning.

Best practices

Ensure key stakeholders have access to the ServiceNow CORE Compliance Portal

Establish a formal procedure to identify relevant parties, including compliance teams, vendor risk assessment teams, and security personnel who require access to CORE documentation for internal audits and vendor evaluations, and provide them with the necessary portal access.

Periodically review the ServiceNow CORE Compliance Portal

Establish a process involving relevant stakeholders to conduct regular reviews of CORE content and implement a method for collecting and addressing clarification questions following material review.

Use the completed questionnaires in the ServiceNow CORE Compliance Portal to support due diligence efforts

Use the ServiceNow pre-completed [Consensus Assessment Initiative Questionnaire \(CAIQ\)](#) and [Standardized Information Gathering \(SIG\) questionnaire](#) to simplify your evaluation process. (Links require access to the ServiceNow CORE Compliance Portal. Find out how to access CORE [here](#).) These resources save time, speed up risk assessments, and help stakeholders quickly find key details for audits. For any questions, our account teams are available to assist promptly.

Periodically review the ServiceNow Customer Security Portal

Establish a process to conduct regular reviews of the Customer Security Portal, including compliance certifications, security advisories, Common Vulnerabilities and Exposures (CVEs) s, SOC reports, and instance security best practices. Whether evaluating ServiceNow as a vendor or seeking guidance on instance security, this portal serves as a centralized resource for all ServiceNow security needs.

Additional information



[Video: ServiceNow CORE Compliance Portal](#)

- [ServiceNow Customer Security Portal](#)
- [Cloud Security Alliance \(CSA\) STAR Level 1 \(CAIQ and EU Cloud\) and Level 2 \(STAR Certification\)](#)

The links below require access to the ServiceNow CORE Compliance Portal. Find out how to access CORE [here](#).

- [Higher Education Community Vendor Assessment Toolkit \(HECVAT\)](#)
- [Standardized Information Gathering \(SIG\) questionnaire](#)
- [ServiceNow CORE Compliance Portal Directory](#)

IDENTIFY

Instance management

Customer responsibility

Customers must oversee all the organization's production and sub-production ServiceNow instances, ensuring each one's purpose, owner, and data classification are known.

Best practices

Maintain a centralized inventory of instances

Maintain a centralized, up-to-date inventory of all ServiceNow instances (see the [ServiceNow Support Instances Dashboard](#)). Clearly identify each instance by name and URL, environment type (such as Production, Development, Test, or Sandbox), business purpose, designated business and technical owners, and data classification.

Regularly review all instances

Conduct regular reviews of all production and sub-production ServiceNow instances to verify each instance's ownership, purpose, and ongoing alignment with business needs. Document each review and its findings and formalize the follow-up process to support continuous oversight.

Align with change management

Changes to ServiceNow instances should follow the organization's change management process. Document each activity with an official record and obtain approvals before proceeding to ensure tracking, authorization, and compliance.

Plan for acceptable use

Customers should work with all stakeholders to define appropriate usage guidelines for ServiceNow. This guidance should be published in the organizational standards, when appropriate. Manage instance activity in accordance with company guidelines throughout each instance's lifecycle.

Retire unused instances

Decommission ServiceNow instances that are no longer needed, following the organization's documented retirement process that includes backing up critical data, removing all integrations and credentials, and updating the centralized inventory to reflect changes.

Additional information

- [Requesting instance retire via service catalog on ServiceNow Support](#) (requires a ServiceNow Support account)

PROTECT

Vulnerability management

Customer responsibility

Customers should apply patches and upgrades in a timely manner and test all configuration changes in a non-production instance before deploying to production. To maintain support and security, customers must ensure their instances comply with ServiceNow EOL.

ServiceNow responsibility

ServiceNow maintains an ongoing infrastructure vulnerability program described in the [Commercial Cloud vulnerability management SOP](#), using third-party commercial and in-house tools to identify vulnerabilities in the ServiceNow perimeter and for all cloud and corporate systems (link requires access to the ServiceNow CORE Compliance Portal, find out how to access core [here](#)). There are two releases of the ServiceNow AI Platform per year. In addition, patches and hotfixes are produced throughout the supported lifetime of a major release and rolled into the codebase for inclusion in the next version.

ServiceNow publishes Security Advisories to inform customers of relevant vulnerabilities, mitigations, and risks affecting the ServiceNow AI Platform and supporting cloud environments. Through the Patching Program, ServiceNow delivers regular updates that include security, performance, and functional fixes to customer instances. ServiceNow enforces an End-of-Life (EOL) policy to ensure that only supported versions receive updates, helping maintain a secure and stable platform for all customers.

Best practices

Regularly review the ServiceNow security advisories page

These advisories often highlight vulnerabilities addressed through patches or upgrades, ensuring customers can apply updates promptly to maintain security and compliance. Work with stakeholders, such as the security team, when necessary to apply, mitigation and patch the ServiceNow instance, as needed.

Test changes in non-production first

Before applying any configuration changes to a production environment, it is essential to test them in a non-production instance. This practice helps identify potential issues, ensures compatibility with existing workflows, and reduces the risk of service disruptions.

Understand and follow the ServiceNow Patching Program

As the instance administrator, it is important to understand and follow the ServiceNow Patching Program. This program updates customer instances to required patch versions periodically throughout the year.

Through these updates, instances receive current security, performance, and functional fixes. Patching addresses known security vulnerabilities and forms a standard part of any patch management process.

Best practices continued

Know the difference between software updates and upgrades

Understanding the difference between a software update and an upgrade is essential for maintaining both security and support in your ServiceNow environment.

- **Software updates:** Patches and platform fixes delivered throughout the year via the ServiceNow Patching Program. These address known vulnerabilities and improve performance without changing the platform version.
- **Upgrades:** Moving to a newer major platform version, typically released twice a year, which includes enhanced features, architectural improvements, and broader functionality.

Both are critical but serve different purposes in keeping your instance secure, stable, and supported.

Adopt a proactive patch management process

Establish and follow a routine schedule to promptly install security patches and platform updates in both production and sub-production environments. Treat production and sub-production systems with equal diligence, ensuring that all environments are updated.

Ensure instances remain on a supported family release

ServiceNow releases two major version updates per year and only supports the current version (N) and one prior release (N-1).

Instances operating on older family release are categorized as “End-of-Life” (EOL) and do not receive new updates or patches. Organizations should establish and maintain a formal process to proactively track their ServiceNow instance’s family release version, ensuring timely upgrades before the platform reaches EOL status.

Additional information

- [Commercial cloud vulnerability management SOP](#)
(Requires access to the ServiceNow CORE Compliance Portal. Find out how to access CORE [here](#).)

The links below require a ServiceNow Support account:

- [Shared responsibilities: Vulnerability assessments](#)
- [Security advisories page](#)
- [ServiceNow Patching Program FAQs](#)
- [End-of-life \(EOL\) policy](#)
- [Understanding supported servicenow releases and the patch lifecycle](#)

Identity and access management

Authentication

Customer responsibility

In the context of the Security [Shared Responsibility Model](#), customers have the responsibility of configuring their instance using supported authentication methods. This configuration process may include setting up multi-provider single sign-on (SSO) with security assertion markup language (SAML) or OpenID connect (OIDC), enabling smartcard authentication such as personal identity verification (PIV) or common access card (CAC) for environments requiring high security, utilizing OAuth, and enforcing multi-factor authentication (MFA).

Additionally, it involves disabling local logins to enhance security. By default, MFA is enabled for all local logins, and customers must manage exceptions and monitor to ensure this default setting is maintained. The authentication mechanism plays a crucial role by verifying the identity of users accessing a ServiceNow instance and subsequently authorizing them to access features that correspond to their role or job function.

Best practices

Change default passwords

ServiceNow instances come with certain built-in accounts such as "admin," "ITIL," and "employee" which are provisioned with default passwords, unique to the instance. Customer admins should change all default passwords for built-in accounts immediately upon instance creation, ensuring that each new password meets your organization's complexity and strength requirements.

Configure and enforce strong password policies

It is important for customers to set password policies for their Identity Provider (IdP) and within their ServiceNow instance(s). This includes specifying requirements like minimum password length, complexity, expiration, uniqueness, and lockout conditions for native accounts. Also, be sure configurations meet your organizational standards.

Enable account lockout to prevent brute force attacks

As a critical security best practice, customers should enable account lockouts both on their IdP and for all local accounts within the ServiceNow instance. This measure is essential to defend against brute force authentication attacks by automatically locking accounts after a set number of failed login attempts.

Manage IP address access control

Limit which IP addresses are allowed or denied access to the ServiceNow instance. If a VPN or another method is used to route traffic through a known set of IP addresses, access to the instance should only be allowed for that range of addresses.

Note: IP address access control does not limit access for ServiceNow support personnel. Customers can enable the [SNC access control plugin](#) to restrict instance access to specific personnel, or restrict access without their express permission. Enabling this plugin may affect the ability of ServiceNow support to help a customer if they are locked out of their instance.

Consider API authentication

API access can use either standard user identities (interactive) or machine identities (non-interactive). Evaluate your authentication from both perspectives.

Assess whether local login requires restrictions

Collaborate with stakeholders, including IT, security, and business leaders, to evaluate whether local login methods should be restricted for interactive sessions. Consider potential risks, operational requirements, and integration needs.

Best practices continued

Integrate MFA with existing IdPs

Enable MFA with your existing IdP to strengthen account security. Additionally, customer admins can require high-privileged users to authenticate with FIDO2 authenticators that use stronger methods, passwordless devices, or biometrics, ensuring more protection for sensitive actions.

Customers can also allow low-privileged users to authenticate with an email one-time password (OTP) or a short message service (SMS) OTP. These methods are easy to use and require minimal setup.

Review the MFA dashboard

Use the MFA Dashboard to gain MFA insights such as user enrollment, privileged admins who haven't opted in to MFA, and compliance. To enhance instance security, the MFA dashboard will help customer admins confirm that all users have enabled MFA.

Use the Machine Identity Console

Use the [Machine Identity Console](#) to gain comprehensive visibility into the security posture of your inbound integrations, such as those used for service accounts, across the ServiceNow AI Platform.

Review guidance around password spray attacks

Review the guidance in the [Password Spray Attack Mitigating Strategies \(KB0726312\)](#) (link requires a ServiceNow Support account) and work your security team to apply any relevant recommendations.

As of the Yokohama release, MFA is enabled by default for local logins, using built-in authentication. It is important to understand default MFA for local logins, high-privilege accounts, and sensitive roles. Teams should ensure that this default MFA setting is communicated to all relevant stakeholders. If a ServiceNow instance is not yet upgraded, enabling MFA for all admin users is recommended.

- Ensure all local account users are enrolled in MFA within the required timeframe ([30 days after first login](#)).
- Monitor local login access to verify MFA enrollment compliance.
- Enforce MFA for admin accounts and roles with elevated access rights.
- Define groups or roles that must always authenticate using MFA, regardless of login method.

Implement adaptive authentication for granular access control

Collaborate with relevant stakeholders, including security teams, to assess the necessity of implementing Adaptive Authentication policies that limit access exclusively to verified external addresses, such as those originating from the customer's gateway or web proxy.

- Employ Adaptive Authentication to enforce access policies using signals like IP range, user role, group membership, and device posture.
- Apply these controls consistently to both UI logins and Web Services/API access.
- Enable step-up authentication or actions based on risk and user context.
- Configure IP allow lists to restrict traffic to trusted sources such as customer gateways or proxies.
- Account for all user access patterns, including remote and mobile.
- Assess whether to use Step-Up MFA for high-risk access and Step-Down MFA when trust exists.

Best practices continued

Understand Account recovery (ACR) capabilities

When utilizing Single Sign-On (SSO), ensure that at least one Account Recovery (ACR) administrator is registered prior to activation. This precaution secures fallback access to critical systems should primary authentication methods become misconfigured or unavailable. Thoroughly document all ACR procedures, limit access strictly to authorized personnel, and regularly audit ACR usage to uphold strong security standards. Restrict local logins for interactive sessions to approved recovery users with MFA enabled and employ ACR solely as a recovery tool to maintain system integrity.

- ACR removes local login options when SSO is active, for example, local database authentication and LDAP authentication.
- ACR controls do not apply to non-interactive access, because local database authentication is often needed for inbound integrations. Instead, use API Access Policies to specify accepted authentication types and criteria for REST and SOAP APIs. Authentication profiles for APIs can also be used with [System or Export Processor access policies](#).

Additional information

- [Change default passwords](#)
- [Configure password policies](#)
- [Specify lockout for failed login attempts](#)
- [Restrict access to specific IP ranges](#)
- [API authentication](#)
- [Non-interactive sessions](#)
- [Time-limited authentication](#)
- [Configuring multi-factor authentication \(MFA\)](#)
- [MFA enforcement](#)
- [MFA Dashboard](#)
- [Machine Identity Console](#)
- [Adaptive authentication](#)
- [Account recovery \(ACR\)](#)
- [Access policy for System or Export Processors](#)

The links below require a ServiceNow Support account:

- [How to limit local login when using single sign-on \(SSO\)](#)
- [Password spray attack mitigation strategies](#)

Authorization

Customer responsibility

Customers are responsible for defining user roles based on job functions and assigning appropriate permissions using role-based access control (RBAC) and access control lists (ACLs). It is recommended to configure ACLs to enforce the principle of least privilege and use non-production instances to test changes before deployment.

Best practices

Distinguish between interactive vs non-interactive user accounts

Interactive user accounts should use MFA and role-based access controls, ensuring least privilege and tying actions to individuals for accountability.

Non-interactive accounts, intended for integrations and automation, should authenticate via API keys or OAuth tokens, have roles restricted to their purpose, utilize IP restrictions when possible, and link actions to the system or team.

The key differences include accountability (individual vs system), licensing, authentication, and lifecycle management. Both require strict least privilege, but non-interactive accounts need extra controls like credential rotation, monitoring for unusual API activity, and clear ownership documentation to prevent unauthorized system access.

For integration accounts, enable the web services access flag to prevent those accounts from using interactive sessions.

Define roles clearly

Identify each job function that will interact with the ServiceNow AI Platform and assign specific user roles with clear names and descriptions. Update roles as business needs evolve and communicate privileges to users. Adopt the concept of least-privileged access. This ensures effective access control and simplifies auditing.

Ensure each user has a unique user account

Ensure that every user is assigned a unique user account within the system. This approach strengthens accountability, enables precise access management, and supports auditing of user activities.

Machine Identity Console

A machine identity refers to a service account used for inbound API integrations. The Machine Identity Console provides visibility into these identities by listing all accounts with Web Service Access Enabled set to true and/or those that have accessed an API.

These identities are critical for automation, integration, and secure communication, but they're often invisible and unmanaged. To maintain security and accountability, ensure that individual user accounts are separate from service accounts used for supporting unattended or automation processes.

It is recommended that customers limit the use of personal identities for executing unattended automations or integrations. By implementing ServiceNow access policy restrictions to clearly separate these data flows, organizations can better define and uphold policies aligned with their identity architecture.

Use security attributes when possible

Customers should utilize applicable security attributes when possible. Security attributes offer an alternative method for access control via role definitions.

Use security data filters when possible

Security data filters enable access restriction to records based on a user's role, or other security attribute-related assertions. Security data filters are applied before a query is executed and ensure only authorized users can view records regardless of how data is accessed. Customers should explicitly enable security data filters for user-facing queries that are not using **GlideRecordSecure**.

Note: Security data filters may impact system performance and slow query and page load times, if not used carefully.

Best practices continued

Limit concurrent sessions

Work with your security team to determine if you need to [limit concurrent sessions](#) for the same concurrent interactive sessions to reduce the risk of session hijacking or credential abuse.

Evaluate adaptive authentication with Session Validation Context

Evaluate the adaptive authentication's [Session Validation Context](#) to automatically end user sessions if the session's IP address changes unexpectedly. This approach helps maintain security by ensuring that only users accessing from their original network context can continue their sessions.

Activate default deny with High security plugin

The [High security plugin \(HSP\)](#) is installed and enabled by default on all new ServiceNow instances. Customers can set a [default deny property](#), which prevents read, write, create, and delete for all tables, unless explicit permission is given for a user or role in an ACL rule. Verify the plugin is enabled.

Understand the difference between Allow-If and Deny-Unless ACLs

Allow-If allows access upon successful evaluation and is the default ACL. Deny-Unless denies access unless there is a successful evaluation. Deny-Unless ACLs will take priority against Allow-if ACLs in ACL Evaluation as it will be evaluated first. The Deny-Unless ACL defines the users that will NOT be denied. Said another way, the user will be denied access unless the role, condition, and script requirements are met.

Verify Security Jump Start—ACL Rules Plugin is enabled

All new ServiceNow instances have the [Security Jump Start—ACL Rules plugin](#) installed to provide a base level of access security for key system tables. Use this plugin to establish foundational ACL protections for sensitive system data.

Enable automatic account creation only when necessary

Automatic account creation allows user accounts to be [created dynamically by email](#). This feature should be used with care. Activate this feature if necessary for a specific use case. Regularly review whether this feature is still needed and disable if not.

Understand access by ServiceNow personnel

Collaborate closely with stakeholders to ensure everyone is informed about the circumstances under which ServiceNow personnel may access customer data. Access is restricted to designated customer support employees assigned to open support cases and is only granted with explicit customer authorization. All such access is temporary, tightly controlled, and fully auditable. Customers are encouraged to actively monitor their instance event logs and use the Security Center widget to review access events, ensuring full transparency and reinforcing trust in the security of their data. Customers can identify this activity at any time by tracking the occurrence of the identifier name@snc in the instance event logs.

Activate the ServiceNow Access Control (SNAC) plugin for enhanced control

Customers may choose to activate the [ServiceNow access control plugin](#), which enables customers to control which ServiceNow customer service and support employees can access their instance, and when. Review the plugin with stakeholders to determine if it needs to be enabled. Once this control is enabled, ServiceNow personnel must request ad-hoc, time-bound access.

Use Contextual Security Manager to evaluate table access when possible

The Contextual Security Manager works alongside the broader security framework at ServiceNow, which includes ACLs that can be applied to individual records and fields within tables. This allows for much more sophisticated access control than simple role-based permissions. The plugin is particularly useful when you need security rules that depend on the specific circumstances of the access request rather than just the user's assigned roles. This makes it valuable for complex enterprise environments where access requirements vary based on data context, business rules, or dynamic conditions.

Best practices continued

Use Access Analyzer to review access controls

Use ServiceNow Access Analyzer to conduct regular audits of user, group, and role permissions for core platform elements such as tables, script includes, UI pages, and REST endpoints. Schedule governance reports and include IT security and compliance stakeholders during the review process as appropriate. This method helps evaluate least-privilege access across the ServiceNow AI Platform.

Establish a regular access review process for Access Analyzer reports

Customers should establish processes to perform regular reviews of the reports to ensure that only authorized personnel have appropriate access:

- Define a review cadence (e.g., quarterly) for auditing access reports.
- Involve appropriate stakeholders such as IT security, compliance, or application owners.
- Remove or adjust permissions as needed to enforce least access.
- Generate and retain reports regularly to support audit, compliance, and governance activities.

Implement identity provisioning with SCIM

Review the information on the [System for Cross-Domain Identity Management \(SCIM\) plugin](#), which enables customers to efficiently provision and manage user identities, group memberships, and additional attributes from external sources using an industry-standard protocol. The SCIM plugin can be used to automate user and group management from sources like Active Directory, AWS, or Okta.

Additional information

- [Exploring access control lists \(ACLs\)](#)
- [Security Attributes fundamentals](#)
- [Non-Interactive sessions](#)
- [Machine Identity Console](#)
- [Roles](#)
- [Security data filters](#)
- [Limit concurrent sessions](#)
- [Adaptive authentication with Session Validation Context](#)
- [Default deny plugin \(instance security hardening\)](#)
- [Security jump start—ACL rules plugin](#)
- [Automatic user creation](#)
- [ServiceNow SNC Access Control plugin](#)
- [High security plugin \(HSP\)](#)
- [Contextual Security Manager](#)
- [Access Analyzer](#)
- [Activating the SCIM plugin](#)
- [Time-limited roles](#)

ServiceNow Security Center

Secure instance configuration

Customer responsibility

Users can monitor the [ServiceNow Security Center \(SSC\)](#) to review hardening settings, security scanner outcomes, and metrics related to instance security. Customers are required to prioritize hardening configuration options in Security Center according to their organization's requirements.

Best practices

Establish security hardening priorities

Collaborate with relevant stakeholders to develop a comprehensive hardening plan related to a ServiceNow instance that aligns with the organization's security strategy and priorities. Create a process to apply the plan to a ServiceNow instance using the security hardening setting in ServiceNow Security Center.

Address noncompliance with security hardening and hardening compliance score

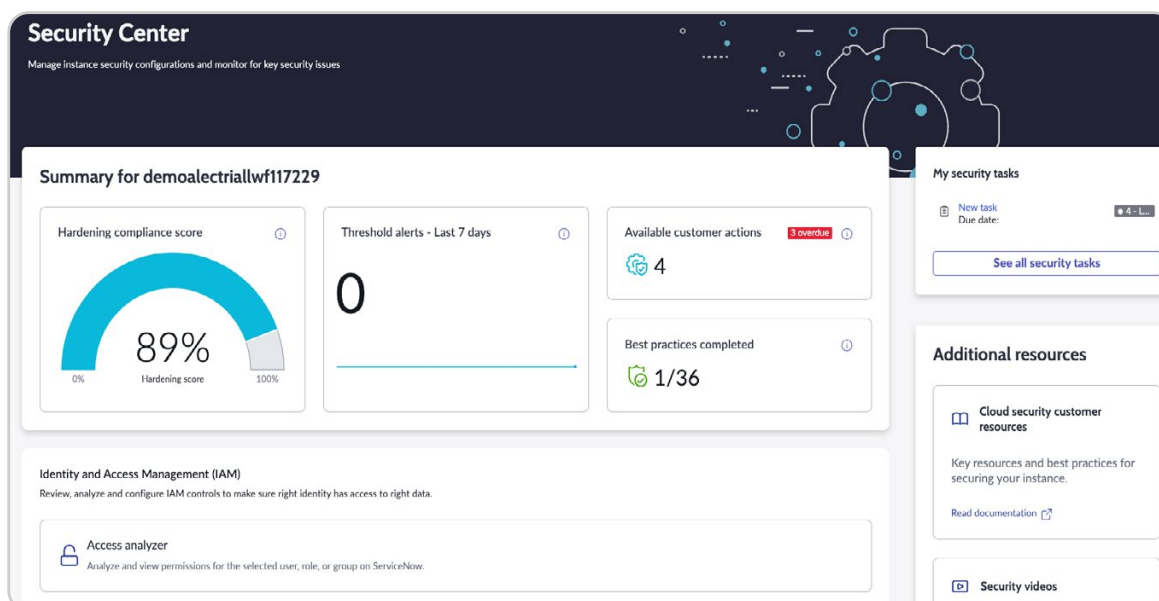
Use [Security hardening](#) to identify, test, and assess noncompliance in a sub-production instance. Review the hardening compliance score to determine how closely your instance aligns with SSC hardening recommendations.

Note: A high compliance score does not guarantee that the instance is fully secure—it only reflects alignment with SSC hardening settings.

Run Security Center security scans regularly

The [Security scanner](#) helps discover and correct access control misconfigurations. Use the Security Scanner built-in to SSC to scan your instance against a set of security checks in order to identify misconfigurations on a regular cadence.

- **Scan comparison:** Compare two scans from the same security suite and view results in a dashboard.
- **Scan checks:** Identify issues and implement security recommendations for your organization.
- **Custom scan suites:** Create and schedule custom suites to analyze your instance's security posture.
- **Scan findings:** Identify records that violated rules, locate the source record, and review the number of times it triggered specific checks.



Best practices continued

Understand the goal of ServiceNow Security Center metrics

Built-in security metrics in the Security Center provide data on potential threats and trends, allowing users to observe key indicators and set up alerts. These metrics and dashboards are primarily intended for raising awareness rather than continuous monitoring. Organizations with more advanced needs can integrate a Security Information and Event Management (SIEM) solution for real-time tracking and automated response. It is important to assess whether SIEM integration is necessary for your organization's security team to enhance the capabilities provided by Security Center metrics. For detailed guidance on SIEM integration, refer to the [logging and monitoring section](#).

Review and complete customer actions promptly

Increase your instance's security posture by ensuring that system-recommended Customer Actions are implemented on time.

Customer Actions guide you through scanning, updating, and testing security updates on your instance. Unlike automatic updates applied during family releases or patches, [Customer Actions](#) require manual implementation to address specific security needs.

Additional information



[Video: How Does Security Center Help Me?](#)



[Video: ServiceNow Security Center—Hardening](#)

- [ServiceNow Security Center \(SSC\)](#)
- [Security hardening](#)
- [Security metrics](#)
- [Security scanner](#)
- [Custom security scan suites](#)

Analyze Permissions

Access Simulator

Settings

Analyze access and permissions

View permissions for a selected user, role, group, or compare access for two users

Evaluate access

Compare user records

Compare user access

Evaluate permissions for a selected user, role, or a group

Analyze by

User

Select user

Abel Tuter

Rule type

Table (record)

Select table

(Deprecated) Device collection

Select record

Created 2022-01-17 01:53:41

Select field

Short description

Abel Device Collected

Evaluate access

How to evaluate access

Watch a tutorial on how to use access and permissions analyzer

Helpful resources

- [Access Analyzer documentation](#)
- [Knowledgebase articles](#)

Compare access guide

For comparing the access, you can perform the following analysis:

Overview

Permissions for Abel Tuter

User

Abel Tuter

Table

(Deprecated) Device collection

Record

41

Last modified

2025-11-20 14:25:19

Access results

Operation	Overall Access	ACL	Access handler	Data filtration	Execution time	Insights	Execution ID
report_view	Passed	Passed	Skipped	Skipped	2025-11-20 14:25:19		AREX00010C
write	Blocked	Blocked	Skipped	Skipped	2025-11-20 14:25:19		AREX00010C
read	Passed	Passed	Skipped	Skipped	2025-11-20 14:25:19		AREX00010C
add_to_list	Passed	Undefined	Skipped	Skipped	2025-11-20 14:25:19		AREX00010C
save_as_template	Passed	Undefined	Skipped	Skipped	2025-11-20 14:25:19		AREX00010C
report_on	Passed	Undefined	Skipped	Skipped	2025-11-20 14:25:19		AREX00010C
personalize_choices	Passed	Undefined	Skipped	Skipped	2025-11-20 14:25:19		AREX000101
create	Blocked	Blocked	Skipped	Skipped	2025-11-20 14:25:19		AREX00010C
list_edit	Passed	Undefined	Skipped	Skipped	2025-11-20 14:25:19		AREX00010C
query_match	Passed	Undefined	Skipped	Skipped	2025-11-20 14:25:19		AREX000101
query_range	Passed	Undefined	Skipped	Skipped	2025-11-20 14:25:19		AREX000101

Presence of a script

Alert icon in any status indicates the presence of a script in the ACL. Review highlighted ACLs to understand the final access. To know more about how these controls are evaluated and review the logic to determine the access. [Refer to the documentation](#)

Access result legend

- [Passed] Access granted
- [Blocked] Access denied
- [Skipped] Did not evaluate
- [Undefined] No rule found

How are permission evaluated?

Evaluation process is carried out by impersonating a user and determining the ACL permission on the resource. Permission rules allow access to the specified resource if all three of these checks evaluate to true:

- Access handlers must evaluate to "Passed", or is empty/undefined
- Data filters must evaluate to "Passed", or is

Encryption

Data in transit

Customer responsibility

The ServiceNow AI Platform provides customers with encryption in transit via HTTPS for user access and API access to the instance. The platform also supports several protocols for integration with customer or third-party systems, including HTTPS, LDAPS, FTPS, and SCP. Customers should configure data in transit encryption methods in accordance with their security policies and use cases.

ServiceNow responsibility

The ServiceNow AI Platform supports default encryption in transit for sessions inbound to the instance using a minimum of TLS 1.2. All attempted access to a ServiceNow instance over HTTP is redirected to HTTPS.

ServiceNow instance email infrastructure supports opportunistic TLS for sending or receiving email.

Best practices

Enforce TLS 1.2 or higher for browser connections

Customer admins should configure their web browsers to use only TLS 1.2, or higher when connecting to their ServiceNow instance.

Note: [Negotiated ciphers](#) are subject to customer browser versions and may be influenced by customer Internet proxy infrastructure. Customers can specify cipher suites in their own browsers or proxies, as well as select the ciphers to be used on their instance.

Configure other protocols for encryption in transit

Admins can also configure other traffic protocols, such as LDAP, SMTP, and SFTP, to use TLS 1.2.

Encrypt email via S/MIME

ServiceNow implementations can support [S/MIME "end-to-end" email encryption](#).

Data at rest

Customer responsibility

Data at rest encryption is **not enabled by default** for customers using the standard ServiceNow Commercial Cloud.

To meet organizational security and compliance requirements, customers **must evaluate** and **implement** appropriate **encryption solutions** for their ServiceNow instance(s).

ServiceNow offers a range of encryption options, including free [Field Encryption Starter](#) and premium solutions such as [Cloud Encryption \(CE\)](#) and [Full Disk Encryption \(FDE\)](#), which are available at an additional cost.

Customers are also responsible for key lifecycle management through the [Key Management Framework \(KMF\)](#). The KMF introduces specific [roles](#) for cryptographic modules and key management operations. Customer admins should review these roles and assign them in accordance with their company's internal security policy.

Key ownership and control

Customers need to determine which type of encryption key they will use on the ServiceNow AI Platform: a **ServiceNow-managed key (SMK)** or **bring your own key (BYOK)**.

Encryption key lifecycle management

- **Generation:** When using BYOK, keys should be generated in accordance with the company's internal security policy and follow the [ServiceNow key preparation guidance](#).
- **Rotation:** Customers should regularly rotate keys to minimize exposure. ServiceNow supports scheduled rotation for SMK and provides notification reminders for BYOK.
- **Storage:** BYOK's should be stored in a secure, protected environment that performs regular backups to ensure that the keys remain available and recoverable, if needed.

Best practices

Choose an encryption method for data at rest in an instance*

The customer's security team should work with stakeholders to thoroughly assess the regulatory and organizational requirements for data stored in their ServiceNow instance(s) to determine if data at rest needs to be encrypted.

Based on this assessment, customers should select the most appropriate encryption method offered by ServiceNow. When implementing the chosen encryption method, ensure encryption settings and key management are configured in accordance with internal policies and compliance standards to safeguard sensitive information throughout its lifecycle.

Customers seeking included functionality

[Field Encryption Starter](#): Data stored within a ServiceNow instance can be protected with Field Encryption Starter, which allows customers to encrypt specific fields within the instance using AES128 or AES256 encryption.

The key itself is stored within the instance and is protected via the ServiceNow AI Platform using Key Management Framework.

Customers seeking enhanced data protection can license additional encryption features

Platform Encryption Bundle: Combines Field Encryption Enterprise, Cloud Encryption, and the Key Management Framework (KMF) for comprehensive encryption coverage.

• **[Field Encryption Enterprise](#):** Enables granular, field-level encryption with flexible policies, API support, and customer-managed key capabilities.

• **[Cloud Encryption \(CE\)](#):** Provides volume-level encryption, supporting customer managed keys.

[Full Disk Encryption \(FDE\)](#): Encrypts physical disks at the hardware layer and requires dedicated hosting infrastructure.

* ServiceNow encryption options can be used individually or in combination.

Best practices continued

Monitor and protect sensitive roles

Track and monitor changes to sensitive roles (e.g., KMF roles, admin, security_admin) to detect and alert any unauthorized modifications. For more detailed guidance, refer to the [logging and monitoring section](#).

Additional information



[Video: Standard Encryption Options](#)

- [Shared responsibilities: Encryption](#) (requires a ServiceNow Support account)
- [Negotiated ciphers](#)
- [Field Encryption Starter](#)
- [Field Encryption Enterprise](#)
- [Cloud Encryption with Key Management](#)
- [Full Disk Encryption](#)
- [Key Management Framework](#)
- [Cryptographic module overview](#)

AI security

Customer responsibility

Customers are responsible for the use and oversight of artificial intelligence (AI) and machine learning (ML) within their ServiceNow instances. Through configuration, customers determine how and when to deploy the AI/ML features within their ServiceNow instance. Customers must review AI/ML use cases and decide whether or not they meet their requirements from regulatory, ethical, and business-use perspectives.

Consider your AI security strategy

- **Engage key stakeholders:** Identify all stakeholders involved throughout the AI lifecycle and clearly define and document their roles and responsibilities.
- **Define system purpose:** Clearly articulate the task and intended purpose of each AI system.
- **Enable human oversight:** Establish procedures that allow authorized personnel to interrupt, override, or halt system operations when necessary.
- **Provide contestability:** Implement mechanisms for challenging automated decisions, ensuring human operators can review actions taken by AI systems and, if appropriate, supplement them.

Customers should establish accountability for AI-driven processes and implement appropriate controls to guard against unintended outcomes.

Additionally

- **Document operational boundaries:** Identify user personas and populations, determine who has authority to make changes and control deployment change management, and establish accountability for AI governance policies and procedures. Consider methods intended to maintain security and compliance throughout the AI lifecycle.
- **Assess AI risks:** Review the [Now LLM model cards](#) to understand each model's context, intended use, training data, limitations, and other key details.
- **Train your teams:** Provide comprehensive, role-specific training for developers, operators, and end users. Training should cover authorization and security protocols, data governance responsibilities, and should be regularly updated to reflect evolving technologies, threats, and regulatory requirements.

ServiceNow responsibility

ServiceNow is committed to building and deploying AI responsibly. Our generative AI solutions are designed with human-centric principles, ensuring customers remain in control.

ServiceNow maintains documented AI governance policies and standard procedures that incorporate industry best practices, including AI data governance, dataset lifecycle management, AI development, and deployment. These policies are regularly updated to address emerging technologies, evolving industry standards, and new security threats.

The ServiceNow AI governance process aligns with the NIST Risk Management Framework for AI and complies with all applicable local laws and regulations. As regulations evolve, we continue to adopt, expand, and align with relevant compliance programs to ensure ongoing adherence.

To promote fairness and inclusivity, our AI team uses diverse datasets and conducts regular testing to reduce bias. We are committed to transparency about AI usage, limitations, and governance, fostering trust through oversight, expert collaboration, and community feedback.

ServiceNow recently received [ISO 42001 artificial intelligence, management system certification](#), which covers the AI system lifecycle, from the initial concept phase to the final deployment and operation of the system. This certification helps ServiceNow validate its already stringent security practices, which include robust AI governance, supply chain accountability, and adherence to strict obligations. (Link requires access to the ServiceNow CORE Compliance Portal. Find out how to access CORE [here](#).)

For more information, read the [Responsible AI white paper](#), which outlines the ServiceNow approach to developing and implementing AI solutions.

Best practices

Understand the ServiceNow Data Sharing Program

Collaborate with relevant stakeholders to fully understand how anonymized data is shared with ServiceNow. Confirm the intended data contribution strategy with appropriate stakeholders. Customers of the Advanced AI and Data Products can opt out of sharing data.

Refer to the [Data Sharing Programs and AI Model Improvement \(KB1648406\)](#) for details on how ServiceNow collects and uses customer-contributed data to enhance AI models, as per the [product-specific terms](#).

- Customers can opt out of anonymized data sharing within 30 days of downloading an AI app from the [ServiceNow Store](#).
- Data sharing for the Advanced AI and Data Products can be managed from the Now Assist Admin Console.

Evaluate and configure AI model options on the ServiceNow AI Platform

Some ServiceNow products rely on third-party Original Equipment Manufacturers (OEM) services, such as Azure OpenAI. Collaborate with your stakeholders to determine whether your organization will use these cloud-based models. If they do not meet your security or compliance requirements, configure ServiceNow to fully opt out of options like Microsoft Azure OpenAI, Google Gemini, or Anthropic Claude on Amazon Web Services (AWS).

Note: Certain skills may restrict model provider selection, based on functional or technical limitations. These exceptions are described in [Model Provider Support Matrix for Now Assist Skills and AI Agents \(KB2222333\)](#), which outlines supported skills and agents for both the Now LLM and third-party OEM LLMs.

Data processing in production

When using generative AI services, prompts and responses are processed in memory only—inputs and outputs are not stored or cached by the inference infrastructure. For details on how data is transmitted, processed, and protected during runtime, refer to the [Data Processing for Advanced AI & Data Products FAQ \(KB1584492\)](#).

Evaluate how AI data is securely processed and select either ServiceNow-hosted or third-party LLMs in alignment with your organization's data residency and governance policies.

Note: Third-party LLMs may use global infrastructure to dynamically route traffic to the best available data center for each request. This means the regional processing location may differ from the data center region specified on a customer's order form.

Data for the Advanced AI and Data Products (for example, Now Assist) is processed in ServiceNow data centers by default. During periods of high demand, data may "burst" to Microsoft Azure data centers to maintain consistent performance. Customers can configure this "burst" behavior in the Now Assist Admin Console and opt out when they choose.

Administer Generative AI tools in ServiceNow

Customers should provide the necessary information and access to the relevant Now Assist toolset to the appropriate stakeholders. Maintain a clear authorization process and monitor activity as required to ensure secure and compliant operations.

- **Now Assist Admin Console:** Configure, monitor, and troubleshoot Now Assist applications and skills. This includes assigning models at the skill level, tracking usage, and providing visibility into system behavior.
- **Now Assist Skill Kit:** Equip developers with tools to build and evaluate custom generative AI skills.
- **Now Assist Data Kit:** Enable developers to manage datasets and create evaluation collections to support custom skill development and testing workflows.
- **AI Agent Studio:** Offer a no-code interface for designing and managing AI Agents. Developers can define roles, assign tools, and connect agents to existing workflows using natural language configuration.

Best practices continued

Enhanced protective controls

Implement Data Privacy for Now Assist

Engage stakeholders to assess the need and value of enabling [Data Privacy for Now Assist](#). This solution integrates with the [Generative AI Controller](#) and uses real-time anonymization with configurable data patterns to protect sensitive information before prompts are submitted to the LLM.

Enable Now Assist Guardian for enhanced protection

Collaborate with stakeholders to determine whether Now Assist Guardian is needed to safeguard users and data. This feature monitors LLM requests and responses to detect offensive or harmful content, prompt injection attempts, and filtered topics. Offensive content and injection attempts can be logged or blocked based on your configuration. If a filter is triggered, users are redirected to the Sensitivity Detection: Fallback topic in Virtual Agent.

For detailed implementation guidance, refer to the [Now Assist Guardian](#) documentation.

Leverage [AI Control Tower](#) for governance and risk management

AI Control Tower is a premium offering that gives enterprises visibility into their AI footprint, manages the AI lifecycle, and identifies risks associated with AI investments. AI Control Tower can help ensure that AI models, workflows, and agents are governed, optimized, and aligned with a customer's business strategy.

Customers should collaborate with stakeholders to evaluate the need and value of AI Control Tower for their organization. This solution can govern AI assets and manage the lifecycle for both ServiceNow and third-party AI applications.

For more information, refer to the [AI Control Tower documentation](#).

Additional information

- [Responsible AI white paper](#)
- [Now Assist Guardian](#)
- [Data Privacy for Now Assist](#)
- [LLM service updates | Model cards](#)
- [Reference for Generative AI Controller](#)

The links below require access to the ServiceNow CORE Compliance Portal. Find out how to access CORE [here](#).

- [Data sharing programs and AI Model improvement \(KB1648406\)](#)
- [Model provider support matrix for Now Assist Skills and AI Agents \(KB2222333\)](#)
- [Data processing for Advanced AI & Data Products FAQ \(KB1584492\)](#)
- [Enterprise artificial intelligence governance policy](#)
- [Artificial intelligence development policy](#)
- [ServiceNow artificial intelligence \(AI\) Services SOC 2 Type 2 Report](#)

Secure coding

Customer responsibility

Customers are responsible for any custom code they develop on the ServiceNow AI Platform. All custom development should follow secure coding best practices to minimize security risks.

ServiceNow responsibility

ServiceNow follows a “build security in” strategy to identify and reduce risk throughout the Software Development Lifecycle. This approach includes security education, best practices, iterative security design, and continuous security analysis, enabling product teams to deliver robust and secure software.

Best practices

Review ServiceNow Software Development Lifecycle SOP

Regularly review the ServiceNow [Software Development Lifecycle SOP](#) with stakeholders, such as security and compliance teams, to ensure everyone understands the process and can address any questions (link requires access to the ServiceNow CORE Compliance Portal. Find out how to access CORE [here](#)).

Refer developers to the Secure Coding Guide

Always adhere to secure coding best practices when developing applications. The [Secure Coding Guide](#) provides detailed recommendations on topics such as input/output sanitization, session management, secure access, and more (link requires a ServiceNow Support account).

Additional information

The links below require a ServiceNow Support account:

- [Shared responsibilities: Secure coding](#)
- [Secure Coding Guide](#)

The links below require access to the ServiceNow CORE Compliance Portal. Find out how to access CORE [here](#).

- [Software Development Lifecycle SOP](#)
- [Code Control SOP](#)
- [Maintenance Release Management SOP](#)

MID Server security

Customer responsibility

Customers are responsible for ensuring the security of the MID Server by maintaining strict physical controls, deploying and hardening the server and operating system in accordance with their internal IT policies, and restricting network access to only essential services and infrastructure. They are also responsible for operating the MID Server and managing account credentials. Additionally, customers must monitor firewall and proxy configurations to allow only the necessary connections.

Best practices

Secure physical access to the MID Server

Place the MID Server in a physically secure location, such as a locked data center or server room, with access restricted to authorized personnel. Follow your organization's access audit requirements to detect and prevent unauthorized entry.

Harden the MID Server and operating system

Deploy and secure the MID Server's operating system and runtime environment according to your organization's IT security policies. Use only [supported operating systems](#) that receive security updates. The MID Server Java application runs on supported Windows or Linux servers with a Java Runtime Environment.

Harden server and operating system for MID Server security

Ensure that the server operating system and runtime environment are deployed, secured, and hardened in accordance with the organization's established internal IT security policies and operational procedures. Operate only on supported operating systems that continue to receive security updates. The MID Server Java application runs on supported Windows or Linux Servers with a Java Runtime Environment.

Enforce network security for MID Server

Limit the MID Server's network connectivity to essential services only. Configure protocols such as SSH, WMI, PowerShell, SNMP, and WBEM as needed. When possible, use MID Server mutual authentication with the ServiceNow instance and restrict access to trusted networks using [Adaptive authentication](#) or [Zero Trust Access \(ServiceNow Vault entitlement required\)](#).

Define your credential and access strategy

Customer administrators should carefully review available service account options. This may require collaboration with stakeholders to choose identities that meet the use case requirements and align with the applicable corporate IT security policies. Consider the following authentication and authorization capabilities:

- Decide between agent-less, agent-based, or hybrid access.
- Establish a credential management strategy (Credentials table or External Credentials Storage — i.e., CyberArk).
- The Windows MID Server uses the login credentials of the MID Server service by default.
- For non-admin access, consider [Microsoft Just Enough Administration \(JEA\)](#) for basic discovery. For agent-based access, use [ServiceNow Agent Client Collector \(ACC\)](#) and configure allow lists to restrict commands..
- For Linux and UNIX machines and network devices, the MID Server uses the SSH and SNMP credentials configured on the instance.
- MID Servers can be configured to perform [mutual authentication](#) with the ServiceNow instance, employing a TLS client certificate for authentication. Customers use TLS certificates for mutual authentication.

Best practices continued

Implement logging and monitoring for the MID Server

Please review the specific logging and monitoring considerations below related to the MID Server and the [logging and monitoring section](#) in this guide. Collaborate with stakeholders to develop a comprehensive logging and monitoring strategy.

- Consider enabling the MID Server Command Audit Log to track all executed commands.
- Monitor changes to sensitive roles (e.g., **discovery_admin**, **mid_server**) and alert on unauthorized modifications.
- Forward all log data to your internal SIEM platform for correlation and analysis. For detailed guidance on SIEM integration, refer to the [logging and monitoring section](#).

Additional information

- [Securing and encrypting MID Server data](#)
- [MID Server system requirements](#)
- [Prepare network connections for MID Servers](#)
- [Disable outbound SSLv2/SSLv3](#)
- [Installing the MID Server](#)
- [External credential storage](#)
- [ServiceNow Vault](#)
- [Adaptive authentication](#)
- [Zero Trust Access](#)
- [ServiceNow Agent Client Collector \(ACC\)](#)
- [MID Server command audit log](#)
- [MID Server certificate check policies \(enabling certificate validation\)](#)
- [Microsoft Just Enough Administration \(JEA\) Discovery](#)
- [Enable MID Server mutual authentication](#)
- [Shared responsibilities: Logging and monitoring](#)

Email security

Customer responsibility

Customers are responsible for configuring email security features within the ServiceNow AI Platform to align with their organization's security posture and business requirements. The platform allows instances to generate and receive emails for common workflows such as task assignments, change management approvals, and status notifications. Users can also update or respond to requests by replying to these emails. While ServiceNow provides multiple out-of-the-box features to support email security, it is the customer's responsibility to enable and manage these features appropriately to protect their instance and data.

Best practices

Enable email filters and malware protection

Collaborate with stakeholders to determine if the organization needs to use the ServiceNow AI Platform email filter features to manage inbound messages and restrict accepted sender domains.

All inbound email to the ServiceNow AI Platform is analyzed for malware and SPAM scoring. Malware scanning is performed using [ServiceNow Antivirus Protection](#). X-headers are added to messages to reflect the results of this analysis, and customers can interpret and act on these headers using the [Email Filter plugin](#). If a malicious email or attachment is detected, it is quarantined in the instance for inspection.

Leverage the existing organization's email infrastructure

If the organization already has a mature email security environment, consider using that infrastructure through the Advanced Email Setup features.

Customers can integrate their own email infrastructure and security gateways to control how mail to and from the instance is processed. A ServiceNow instance supports integration via SMTP, POP3, and IMAP, and can also read email using Microsoft Graph to connect with Microsoft Exchange Online.

Monitor email and malware metrics

Collaborate with stakeholders to establish effective monitoring of email and anti-malware activity. Configure alerts to proactively identify abnormal email activity or potential malware threats and have documented mitigation measures. There are metrics available in the ServiceNow Security Center (SSC) to review.

Encrypt email with TLS and S/MIME

ServiceNow mail infrastructure is designed to use opportunistic TLS to encrypt email in transit. Ensure the organization's sending and receiving email infrastructure supports this setting.

ServiceNow also supports the Secure/Multipurpose Internet Mail Extensions (S/MIME) standard. S/MIME is an end-to-end encryption protocol for sending digitally signed and encrypted emails, ensuring data confidentiality, authenticity, and integrity. Collaborate with stakeholders to determine if this feature should be configured.

Enable Sensitive Data Redaction for emails

ServiceNow provides an out-of-the-box plugin called Sensitive Data Redaction for Inbound Emails, which customer admins can install. This plugin allows customers to redact sensitive data, such as Social Security numbers, financial information, email addresses, phone numbers. Collaborate with stakeholders to determine if the organization should install and configure the Sensitive Data Redaction plugin to automatically mask sensitive information in inbound emails.

Best practices continued

Enforce email authentication and domain restrictions

Customers can control what domains and users are allowed to send email into their ServiceNow instance, as well as what domains and users are valid email destinations using system address filters. Collaborate with your security and IT teams to determine if you need to configure any of the following email controls.

ServiceNow provides Sender Policy Framework (SPF) records to identify email hosts that are approved to send as ServiceNow. To use SPF services, the customer's email systems must be configured to accept mail from the ServiceNow email infrastructure. ServiceNow recommends that customers consume the published ServiceNow SPF records dynamically, rather than allowing by IP address. When allowing by IP address, it is important to note that the addresses may change.

The ServiceNow AI Platform also offers support for Domain Keys Identified Mail (DKIM) and Domain-based Message Authentication, Reporting, and Conformance (DMARC). DKIM is also supported for a custom domain.

Set approved email domains for automatic user account creation

Collaborate with stakeholders to identify and define trusted email domains for account creation, when possible.

Additional information

- [System address filters](#)
- [ServiceNow Antivirus Protection](#)
- [Email Filter plugin](#)
- [Advanced Email Setup](#)
- [ServiceNow Security Center \(SSC\) metrics](#)
- [Sensitive data redaction for inbound emails](#)
- [Secure/Multipurpose Internet Mail Extensions \(S/MIME\)](#)

The links below require a ServiceNow Support account:

- [Sender policy framework \(SPF\)](#)
- [Domain keys identified mail \(DKIM\)](#)
- [Domain-based message authentication, reporting, and conformance \(DMARC\)](#)

File transfers and web services

Customer responsibility

Customers are responsible to thoroughly review, select and configure the file transfer methods and web services settings used within the instance, ensuring that all security configurations align with their organization's policies and standards.

Best practices

Use encryption to secure outbound file transfers during transit

Outbound file transfers from a customer's instance should use secure protocols such as SFTP, FTPS, or SCP to protect data in transit. Outbound clear text protocols such as FTP and HTTP are also supported but not recommended. Inbound transfers such as web uploads are conducted exclusively over HTTPS.

Consider limiting file attachment types

Collaborate with stakeholders to determine whether file attachments should be limited by file extension and MIME type. This approach can help prevent potentially malicious files from being uploaded and stored in the instance.

Monitor antivirus queues for malicious uploads

Customers should establish a defined process for monitoring uploaded file attachments for potential malicious content, leveraging anti-virus scanning capabilities in the platform. This process should include ongoing collaboration with security teams to analyze, identify, and respond to emerging patterns or trends in suspicious uploads, ensuring proactive protection of the instance and its data.

Configure inbound REST API rate limiting

Set rules to limit inbound REST API requests. Customers can create rules that limit the number of inbound REST API requests processed per hour and can also create rules to limit requests for specific users, users with specific roles, or all users.

Review public REST API endpoints

Review the identified REST API endpoint and use cases. Determine if unauthenticated users should be allowed access.

Consider additional restriction policies

Customers can implement [cross-origin resource sharing \(CORS\) rules](#) to control which domains can access specific REST API endpoints. Adaptive Authentication policies can be applied specifically to APIs, restricting both the API endpoint and the web methods employed. ACLs can be required for scripted APIs. An API access policy sets permissions and access duration, allowing you to control inbound ServiceNow API access according to authentication type and filter criteria. The following are the three levels of auth policy support for non-interactive sessions:

- **REST API:** Admin can define a global API auth policy or API specific auth policy.
- **SOAP API:** Admin can define a global API auth policy or API specific auth policy.
- **System and export processors:** Customer administrators can define processor access policies to secure export endpoints. Administrators can block certain export processors, like CSV, PDF, etc. Export processors can also be associated with an authentication profile. For example, if an authentication profile is required to invoke the CSV processor, the user will need to have an OAuth access token to export a CSV.

Note: If you add a global auth policy, then the policy applies for all the REST APIs, SOAP APIs, or System/Export Processors.

Additional information

- [Scripted Rest APIs](#)
- [API access policy](#)
- [Inbound and outbound web services](#)
- [Create REST API access policy](#)

Mobile application security

Customer responsibility

Customers are responsible for implementing and maintaining security measures that protect their ServiceNow mobile environment. This includes enforcing strong [authentication methods such as MFA](#), managing user privileges, and configuring mobile security settings to align with the organizational policies and standards.

Best practices

Configure mobile application security controls

Collaborate with stakeholders to determine the configuration of built-in [mobile security controls](#). This process should include reviewing the following controls to ensure alignment with organizational policies and standards: clipboard restrictions, disabling screenshots, preventing attachments, requiring an in-app PIN, and enabling background blur.

Manage the organization's mobile application distribution

Collaborate with stakeholders to determine how to deploy ServiceNow mobile apps securely using an enterprise mobility management (EMM) or mobile application management (MAM) solution. These platforms enforce security policies, manage app configurations, and protect data—even in bring your own device scenarios. ServiceNow supports distribution through common EMM or mobile device management (MDM) platforms.

Conduct Mobile Application Penetration Testing

Determine whether a mobile application [penetration test](#) is needed by collaborating with your security team and ServiceNow instance administrator. Under the Customer Penetration Testing Policy, customers may conduct regular penetration tests on their organization's ServiceNow mobile applications to identify potential security risks.

Additional information

- [Mobile security white paper](#)
- [Mobile security documentation](#)
- [Mobile security controls](#)
- [User authentication for ServiceNow mobile apps](#)
- [Background blur \(obfuscation\)](#)
- [Cross-origin resource sharing \(CORS\) rules](#)
- [Enable mobile re-authentication](#)
- [Zero Trust Access for Mobile](#)
- [Adaptive authentication for trusted mobile apps](#)
- [Mobile application management \(MAM\) integration](#)
- [Customer penetration testing policy](#) (requires a ServiceNow Support account)

DETECT

Logging and monitoring

Customer responsibility

Customers are responsible for managing and monitoring security-related information within their ServiceNow instance. Extensive logging of transactions, events, and system-level activity is stored in tables within the customer's instance. Customers have access to:

- End-user activity
- Failed login attempts
- Audit trails and record histories
- Administrative escalations
- Access by ServiceNow support personnel

ServiceNow AI Platform transaction logs are retained within the instance for approximately 30 days, event logs for about 7 days, and audit records are retained indefinitely within the instance.

Customers should ensure that the [protected tables plugin](#) is enabled on their ServiceNow instance and that appropriate protection levels are configured. When the property `com.glide.security.protected_table.enabled` is set to true, the platform applies controls designed to prevent privileged users from tampering with critical log tables. This capability is essential for maintaining the integrity of audit data and reducing the risk of unauthorized changes.

To implement protected tables effectively, security teams should review and define the correct protection levels and actions that align with their company policies. It is equally important to incorporate alerts into monitoring procedures so that any attempt to modify protected tables is detected promptly.

By combining these measures, organizations can strengthen compliance, preserve operational transparency, and ensure that sensitive log data remains secure throughout its lifecycle.

ServiceNow responsibility

ServiceNow operates a Security Information and Event Management (SIEM) system to review and correlate logs from multiple network and infrastructure sources. A Scheduled Security Operations Checklist is in place, which includes daily reviews of:

- Linux and Windows systems
- Network devices
- Intrusion Detection System (IDS) alerts
- Behavioral and identified issue logs

High-risk issues, such as intrusion detection events, trigger real-time alerts that are immediately sent to the Security Incident Response Team for review. Network and infrastructure log events are retained for a minimum of 90 days.

Best practices

Define a log monitoring strategy

Coordinate with your security and compliance teams to determine the optimal log monitoring approach for your instance. Decide whether both production and sub-production environments should be monitored, identify storage locations, and establish retention periods. It is essential that the organization defines which events are monitored and how alerts are generated, ensuring comprehensive coverage and swift action against potential threats.

Best practices continued

Monitor and forward logs to the organization's SIEM for threat detection

To enhance threat detection and response, organizations should actively monitor and forward relevant log data from their ServiceNow instance to a SIEM following internal security policies.

Enable Protected Tables plugin to manage log tampering

Customers should ensure the Protected Tables plugin is enabled on their ServiceNow instance and the protection levels are set. When the `com.glide.security.protected_table.enabled` property is set to true, the protected tables plugin will be used to prevent higher privilege users on an instance from tampering with log tables. Collaborate with the organization's security team to review and set appropriate protection levels and actions and add specific alerts that may need to be added to monitoring procedures.

Review event logs to detect unauthorized access and privilege escalation

Regularly review event logs for login activity and privilege escalation to identify and respond to potential security threats. Event logs provide insights into system activity, including successful and failed login attempts and privilege escalation events.

Monitor system logs for configuration changes and errors

Routinely monitor system logs to detect configuration changes, system errors, and unusual data connections that may indicate security or operational issues. System logs contain information about general activity, including configuration changes, system errors, workflows, and inbound/outbound data connections.

Review transaction logs to detect malicious web activity

Review transaction logs to identify unusual or malicious web activity, as they provide records of all browser-based interactions with the ServiceNow instance.

Enable table auditing for complete record history

Customers can enable auditing for database tables, making record history perpetual and allowing tracking of any changes made to the data since creation. By default, only the incident, problem, and change tables are tracked. For other tables, auditing must be enabled manually.

Review import logs to ensure data integrity

Regularly review import logs to track data import activity, including source, status, and timing, to ensure data integrity and detect any anomalies.

Use API Analytics to track inbound API usage

Use API Analytics to monitor inbound API usage and users. Customers can track and analyze inbound REST and SOAP activity with API Analytics. These analytics help customers understand which APIs are being used, by whom, and to what degree.

Additional information



[Video: ServiceNow Security Solutions: Logging and Monitoring](#)

- [Shared responsibilities: Logging and monitoring](#)
- [Log types \(system logs\)](#)
- [Log history](#)
- [Auditing](#)
- [Impersonation logs](#)
- [Log Export Service \(LES\)](#)
- [Syslog probe](#)
- [Avoid Log Tampering](#)
- [Data retention, rotation, cleanup and instance size](#) (requires a ServiceNow Support account)
- [Enable protected tables plugin](#)
- [MID Server command audit log](#)
- [REST and SOAP request \(Outbound web services: Logging\)](#)
- [API Analytics](#)
- [Configuring auditing for a table](#)

Penetration testing

Customer responsibility

Customers may perform application [penetration testing](#) against their sub-production instance(s) in accordance with the ServiceNow Customer Penetration Testing Policy. (Link requires a ServiceNow Support account.)

ServiceNow responsibility

ServiceNow performs nightly web application security testing using automated and manual techniques, along with third-party security scanning tools.

This process ensures that security assessments are integrated during code development. Findings identified during testing are reviewed by the ServiceNow Product Security Team and forwarded to development for remediation.

Prior to each major release (twice per year), ServiceNow engages an independent third-party to conduct comprehensive application penetration testing using industry-standard methodologies.

The assessment typically spans several months and follows an iterative process where findings are remediated by ServiceNow security and development teams. Results of these penetration tests are available to customers and prospects under NDA via the ServiceNow CORE Compliance Portal.

Best practices

Create a process to examine ServiceNow penetration test reports periodically

Create a process to ensure stakeholders, such as your security team, review the most recent published [ServiceNow penetration test reports](#) on the ServiceNow CORE Compliance Portal. Find out how to access CORE [here](#).

Determine if your organization requires penetration testing of an instance

As a security best practice, organizations should collaborate with security and compliance teams to identify which ServiceNow instances require penetration testing and establish a clear process for these assessments. This procedure should be reviewed regularly to ensure it remains aligned with evolving security requirements and organizational needs, allowing timely updates if the scope of testing or risk profile changes.

Define penetration test scope and systematically address findings

For annual application penetration tests, customers are required to install all updates, harden their ServiceNow instance, and meet the prerequisites outlined in the Customer Penetration Testing Policy. After completing these steps, a penetration test can be scheduled.

Administrators should collaborate closely with their organization's security teams to define the appropriate scope and duration for any scheduled penetration tests. Once testing is complete, administrators and security personnel must coordinate to review any findings, prioritize remediation efforts, and establish clear timelines to address findings.

Additional information

- [Penetration test summary reports](#)
- [Customer penetration testing policy](#)
- [ServiceNow CORE Compliance Portal Directory](#)
(Requires access to the ServiceNow CORE Compliance Portal. Find out how to access CORE [here](#).)

RESPOND

Incident management

Customer responsibility

During an incident, customers must lead investigations based on their internal processes, security needs, and regulatory obligations, as ServiceNow cannot anticipate these specifics. In addition, ServiceNow asks that customers keep their security contacts updated in the event that ServiceNow needs to reach out for a suspected incident.

While ServiceNow can assist with questions on the investigation, customers are responsible for classifying related behavior as malicious or benign, given their contextual knowledge. [ServiceNow Support](#) can help interpret log samples but cannot review all logs or determine the full scope of an incident.

To ensure effective assistance, customers are responsible for providing detailed information—such as timelines, IPs, and user data—when requesting support. Broad log queries can delay investigations, whereas targeted data enables faster resolution.

ServiceNow responsibility

ServiceNow, as the data processor, supports customer incident response by querying backend logs upon request, subject to an eight-week retention limit. While customers are responsible for interpreting logs, [ServiceNow Support](#) can help review samples to clarify log types. However, it is essential to note that ServiceNow Support does not have the resources to analyze every event.

ServiceNow Support and security teams assist in identifying possible causes of incidents and offer preventive guidance, though recommendations may be limited by platform capabilities.

At an enterprise level, security teams at ServiceNow have implemented detection rules that initiate internal incident response processes. Detections related to customer instances are normally reported through a support case.

Best practices

Understand your organization's incident response escalation channels

One of the most important variables during a security incident is the time between the incident being reported and when your security team is alerted. To minimize this time as much as possible, ensure that you understand the appropriate contacts within your organization that need to be alerted when an incident is reported. This could be an email address, a catalog item within your internal resources, or a post to a messaging channel. By understanding the initial steps to be taken, customers will be able to quickly respond to an incident, whether it is reported by a company resource or by [ServiceNow Support](#) cases or COMM records.

Ensure security communications from ServiceNow are properly routed

Ensure that your ServiceNow security contacts are updated and security-related COMM records are not being filtered to spam folders. Security contacts can be updated on [ServiceNow Support](#) by a member of the customer's platform team and should receive an email notification for security-related notifications when they are sent. These notifications can come from sources such as cases created for a ServiceNow-detected security incident and COMM records.

Request that the support case be marked as a security case

If a case being submitted involves confirmed compromise of customer information, customers are able to request the case be flagged as a security case, which limits the case visibility as needed. Ensure that security cases are intentionally designated as such. Customer visibility into a security case is limited to the submitter and any accounts designated on the case's watchlist.

Educate your security team on how to raise a case with ServiceNow Support

Ensure that your security team, or at a minimum, the designated security contact in [Security Contacts on ServiceNow Support](#), has documentation on how to create a support case via support.servicenow.com in the event they need to report an incident and cannot contact a member of the platform team.

Understand how to review logs for investigations

One of the most important components of incident response is ServiceNow instance logs. These [system logs](#), will be able to provide customers' security teams with the necessary telemetry for their incident response investigations. Logs can be reviewed using a variety of methods, such as the [log file browser](#), Table APIs, and directly in the platform.

Conduct postmortem activities following a security incident

Following a security incident, it is important to perform a postmortem review of the investigations to determine possible improvements that can be made for future incident response activities. This can include identifying possible communication issues, gaps within the environment's security posture, and ensuring all involved parties understand the root cause of the issue and how to avoid similar situations moving forward.

Additional information

- [System logs](#)
- [Log file browser](#)
- [CORE Directory—Incident Response SOPs](#)
(Requires access to the ServiceNow CORE Compliance Portal. Find out how to access CORE [here](#))

The following links require a ServiceNow Support account:

- [How to report security incidents and security findings to ServiceNow](#)
- [Security contacts in ServiceNow Support](#)
- [Investigating user activity](#)

RECOVER

Business continuity and disaster recovery

Customer responsibility

While ServiceNow manages infrastructure-level disaster recovery and system failover, customers should create and maintain business continuity and disaster recovery plans tailored to their processes and risk tolerance for their ServiceNow instance. This plan should include developing internal communication and response strategies.

By proactively addressing these responsibilities, customers help ensure their organization is prepared to respond quickly and effectively in the event of an unexpected disruption.

ServiceNow responsibility

ServiceNow operates a disaster recovery program for customer instances called the [Information System Contingency Plan \(ISCP\)](#). (Link requires access to the ServiceNow CORE Compliance Portal. Find out how to access CORE [here](#).)

ServiceNow has separate business continuity plans and processes, which are tested annually, in place to ensure availability for the ServiceNow corporate organization and the services it relies on.

Advanced High Availability (AHA) architecture

ServiceNow colocation facilities are arranged in regional pairs, with all customer production data hosted in both colocation facilities simultaneously. ServiceNow uses asynchronous database replication to keep these pairs in sync.

When performing maintenance, or if an infrastructure component fails, transfer between active and passive colocation facilities is executed as part of ServiceNow standard operating procedures. This ensures that when AHA is needed to address an instance failure, the transfer will be successful and service disruption minimized.

If the infrastructure hosting the currently active instance experiences a disruption, ServiceNow activates a failover process that transfers customer operations to the unaffected colocation facility. In this model, the targeted recovery point objective (RPO) and recovery time objective (RTO) durations are one and two hours, respectively.

Backups

The ServiceNow [Advanced High Availability \(AHA\)](#) architecture is the primary means to restore service in the case of a disruption that could impact availability; however, ServiceNow also performs backups of each customer's instance(s).

In specific scenarios, using more traditional data backup and recovery mechanisms may be appropriate.

Backups are stored in the same colocation facilities where the data resides, with production instances backed up in both colocation facilities in the pair.

- Full direct-to-disk backups are performed every seven days and retained for a minimum of 14 days
- Differential backups are taken every 24 hours

Sub-production instances (commonly used for testing and development purposes) are backed up only in their primary colocation facility, because they are not AHA-capable.

ServiceNow responsibility continued

Backup restoration

If a customer deletes data inadvertently, or if a customer's data integration or automation gets misconfigured or malfunctions, this could render data unusable or inaccessible. In these scenarios, [AHA architecture](#) would not be able to recover the deleted data or data loss due to misconfiguration, because with AHA database replication occurs to both instances in the pair at near real-time. Restoring from **backup** is the only option for recovery.

ServiceNow can restore customer data upon request. For more information, see the [ServiceNow Backup and Restoration SOP](#) (link requires access to the ServiceNow CORE Compliance Portal. Find out how to access CORE [here](#).)

Media disposal and destruction

Media disposal and destruction refers to the disposal of hard drives in ServiceNow colocation facilities. ServiceNow follows NIST 800-88 guidelines for destroying hard drives and rendering the media infeasible for future use.

Best practices

Test your company's contingency plans related to the ServiceNow AI Platform

Customers should create and regularly test contingency plans for their ServiceNow installations, using methods such as tabletop exercises. These tests will help verify that communication protocols are clear and procedures function as intended during potential disruptions.

Regularly review ServiceNow plans, policies, and test reports

The Information System Contingency Plan (ISCP) and Corporate Business Continuity Management Policy should be checked often to clarify strategies and address stakeholder questions. The ServiceNow ISCP undergoes annual testing, and the outcomes are documented in the ISCP Test Report. It is advisable to review this report at least once per year.

Additional information

- [Securing the ServiceNow AI Platform white paper](#) (Media disposal section)
- [Advanced High Availability Architecture \(AHA\) white paper](#)

The links below require access to the ServiceNow CORE Compliance Portal. Find out how to access CORE [here](#).

- [Information system contingency plan and test report](#)
- [Corporate business continuity management policy](#)
- [Media sanitization & hardware destruction SOP](#)
- [ServiceNow Backup and Restoration SOP](#)

Conclusion

This guide offers a comprehensive overview of best practices for securing a ServiceNow instance and should be followed by customer administrators, security personnel, and compliance officers.

Organized around the six principles of the [NIST Cybersecurity Framework \(Govern, Identify, Protect, Detect, Respond, and Recover\)](#), this guide offers actionable recommendations for customers to safeguard their ServiceNow instance, as well as an overview of the ServiceNow responsibilities regarding security.

By following these best practices and engaging relevant security stakeholders, organizations can strengthen their security posture, demonstrate due diligence, and maintain compliance across the ServiceNow AI Platform.

Resources

- [Securing the ServiceNow AI Platform white paper](#)
- [Advanced High Availability white paper](#)
- [Cloud Security Customer Resources](#)
- [ServiceNow Trust Site](#)
- [Legal: Customer Agreements and Terms](#)
- [ServiceNow product documentation](#)
- [Cloud Security Alliance \(CSA\) STAR Level 1 \(CAIQ and EU Cloud\) and Level 2 \(STAR Certification\)](#)

The links below require a ServiceNow support account:

- [Shared responsibilities: Encryption](#)
- [Shared responsibilities: Secure coding](#)
- [Shared responsibilities: Logging and monitoring](#)
- [Shared responsibilities: Vulnerability assessments](#)

The links below require access to the ServiceNow CORE Compliance Portal. Find out how to access CORE [here](#).

- [ServiceNow CORE Compliance Directory](#)
- [Higher Education Community Vendor Assessment Toolkit \(HECVAT\)](#)
- [Standardized Information Gathering \(SIG\) questionnaire](#)



By following these best practices and engaging relevant security stakeholders, organizations can strengthen their security posture, demonstrate due diligence, and maintain compliance across ServiceNow AI Platform.

